

CASE STUDY

Secure Architecture Design for an AI-Powered Healthcare Diagnosis Platform

AJAY U

192421237

**CSA5803 DEVSECOPS ENGINEERING AND
APPLICATION SECURITY**

A. Table of Contents
B. Executive Summary
C. Platform Overview
D. Proposed Secure Architecture
E. Data Flow and Threat Modelling (STRIDE)
F. Identified Threats and Risk Assessment
G. Mitigation Strategies
H. Compliance and Governance
I. Conclusion and Recommendations

1. Executive Summary

Artificial Intelligence (AI)-powered diagnosis platforms are increasingly deployed to assist clinicians in detecting diseases, prioritizing cases, and recommending treatment pathways. While these systems improve diagnostic speed and accuracy, they also introduce a uniquely sensitive attack surface: they process highly regulated Protected Health Information (PHI), rely on machine learning models that can be manipulated or poisoned, and their outputs directly influence patient safety and clinical decision-making.

This case study proposes a secure, layered architecture for an AI-powered healthcare diagnosis platform, identifies the principal threats using the STRIDE threat-modelling framework, and recommends concrete mitigation strategies mapped to each threat category. The goal is to demonstrate how security-by-design principles, defense-in-depth, and regulatory compliance (HIPAA, GDPR, HL7-FHIR, ISO 27001) can be embedded into every layer of the system — from user access through AI inference to long-term data storage.

2. Platform Overview

The platform under study allows patients to submit symptoms, medical images, and lab results through a web or mobile application. Clinicians review AI-generated diagnostic suggestions through a dashboard, with an explainability module surfacing the reasoning behind each prediction. The system integrates with external Electronic Health Record (EHR) and Hospital Information Systems (HIS) via HL7-FHIR APIs, and stores data in an encrypted PHI repository.

Core functional components include:

- Patient/clinician-facing applications (web, mobile)
- An API gateway enforcing authentication, authorization, and rate limiting
- A diagnosis orchestration service coordinating the clinical workflow
- An AI/ML inference engine performing diagnostic predictions
- An explainability (XAI) module for interpretable AI outputs
- Encrypted data stores for PHI, tokenized identities, and de-identified training data
- Monitoring, logging, and incident-response infrastructure

3. Proposed Secure Architecture

The architecture follows a defense-in-depth model organized into five layers — presentation, security/gateway, application & AI/ML, data, and infrastructure — each enforcing its own controls so that a breach in one layer does not automatically compromise the others. A compliance and governance layer spans the entire stack.

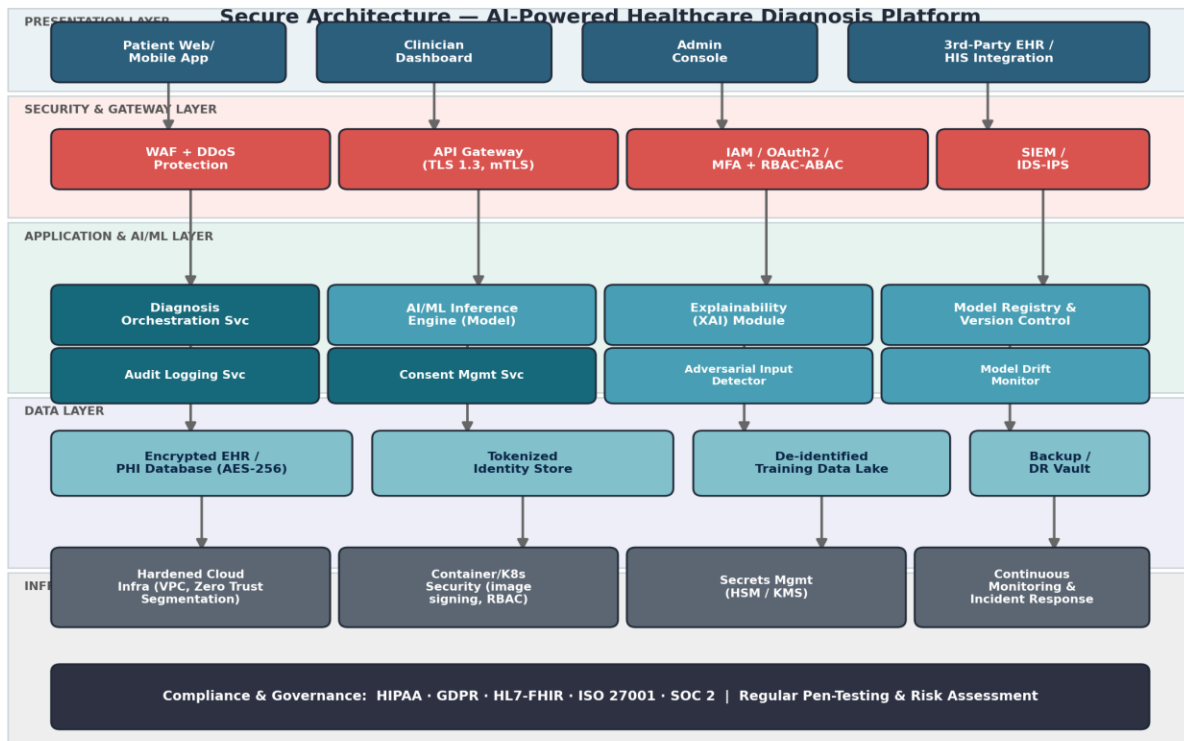


Figure 1: Layered secure architecture of the AI-powered healthcare diagnosis platform.

Key design principles reflected in the architecture:

- Zero Trust network segmentation — no implicit trust between services, even within the internal network
- Least privilege access enforced through RBAC/ABAC at every service boundary
- Encryption everywhere — TLS 1.3 in transit and AES-256 at rest
- Separation of the AI inference engine from raw PHI, using tokenized/de-identified data for model training
- Centralized audit logging and SIEM correlation for real-time threat detection
- Secrets and cryptographic keys managed via a Hardware Security Module (HSM) / Key Management Service (KMS)

4. Data Flow and Threat Modelling (STRIDE)

To identify where security controls are most needed, the diagnosis request lifecycle was decomposed into a data flow diagram and analyzed using the STRIDE methodology (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege). Each trust boundary crossing — from the client to the API gateway, from the orchestrator to the inference engine, and from the model registry back to the clinician — was evaluated for applicable threats.

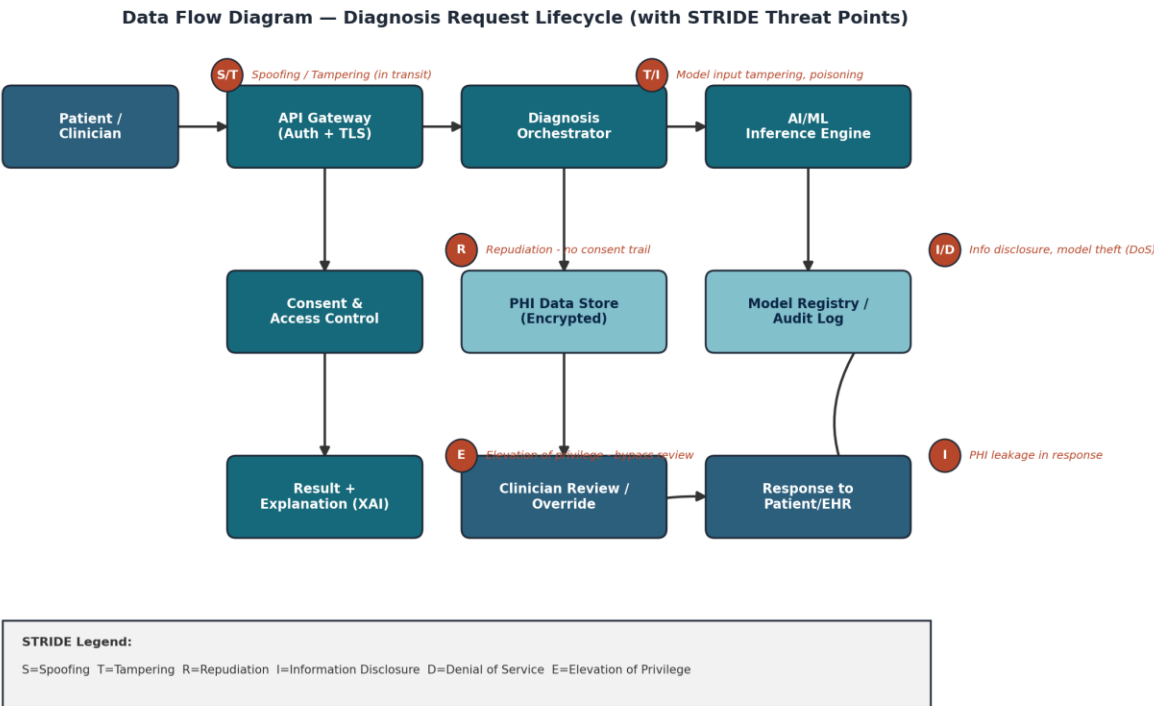


Figure 2: Data flow diagram of the diagnosis request lifecycle with STRIDE threat points annotated.

The diagram highlights that the two highest-value trust boundaries are (a) the ingress point where patient/clinician data enters the system, and (b) the interface between the orchestrator and the AI inference engine, where tampered or adversarial inputs could silently corrupt a diagnosis without triggering conventional security alerts.

5. Identified Threats and Risk Assessment

The table below summarizes the principal threats identified through the STRIDE analysis, the components they affect, and a qualitative risk rating based on likelihood and clinical impact.

STRIDE Category	Threat Scenario	Affected Component	Risk
Spoofing	Attacker impersonates a clinician or patient to gain unauthorized access to the diagnosis portal.	API Gateway, IAM	High
Tampering	Malicious modification of imaging/lab data in transit or at rest to alter a diagnosis outcome.	Data Pipeline, PHI Store	Critical
Repudiation	A user denies having requested or approved an AI-assisted diagnosis, with no verifiable audit trail.	Orchestration Service	Medium
Information Disclosure	Unauthorized exposure of Protected Health Information (PHI) through logs, APIs, or model outputs.	PHI Store, Inference Engine	Critical
Denial of Service	Flooding the inference API to delay or block time-critical diagnoses.	API Gateway, Inference Engine	High

STRIDE Category	Threat Scenario	Affected Component	Risk
Elevation of Privilege	A low-privilege user escalates access to override clinical decisions or retrain models.	RBAC/ABAC Layer, Model Registry	Critical

Beyond generic STRIDE categories, AI-specific threats deserve particular attention in this platform:

- Data poisoning — injecting mislabeled or malicious samples into training data to bias future diagnoses
- Adversarial examples — subtly perturbed images or inputs designed to fool the model into an incorrect diagnosis
- Model inversion/extraction — reconstructing sensitive training data or stealing proprietary model weights via repeated queries
- Model drift — gradual degradation of diagnostic accuracy as real-world data distributions shift over time

6. Mitigation Strategies

Mitigations are mapped directly to the threats identified above, combining preventive, detective, and corrective controls consistent with a defense-in-depth strategy.

Threat	Mitigation Strategy	Control Type
Spoofing	Enforce MFA, OAuth2/OIDC with short-lived tokens, mutual TLS for service-to-service calls.	Preventive
Tampering	End-to-end encryption (TLS 1.3 in transit, AES-256 at rest), cryptographic hashing/integrity checks on datasets and model artifacts.	Preventive
Repudiation	Immutable, cryptographically signed audit logs for every diagnosis request, consent action, and model inference.	Detective
Information Disclosure	Data minimization, field-level tokenization, de-identification for training data, strict least-privilege access policies.	Preventive
Denial of Service	Rate limiting, WAF with DDoS protection, autoscaling inference clusters, circuit breakers.	Preventive / Resilience
Elevation of Privilege	Fine-grained RBAC/ABAC, periodic access reviews, approval workflows for model retraining and deployment.	Preventive
Adversarial/Model Attacks	Input validation and anomaly detection, adversarial-example testing, model drift monitoring, human-in-the-loop review before clinical action.	Detective / Corrective
Insider Threats	Segregation of duties, behavior analytics (UEBA), mandatory audit trails, background checks for privileged roles.	Detective / Administrative

Additional platform-wide safeguards include maintaining a human-in-the-loop review requirement for all AI-generated diagnoses before any clinical action is taken, routine adversarial and penetration testing of the inference pipeline, encrypted and access-controlled model registries, and a documented incident-response plan with defined breach-notification timelines aligned to HIPAA and GDPR requirements.

7. Compliance and Governance

Because the platform processes PHI and produces clinically actionable output, it must be designed against recognized regulatory and standards frameworks rather than security best practice alone:

- HIPAA (US) — Privacy and Security Rules governing PHI handling, minimum necessary access, and breach notification
- GDPR (EU) — Lawful basis for processing, data subject rights, and special-category health data protections
- HL7-FHIR — Standardized, secure interoperability for EHR/HIS integration
- ISO/IEC 27001 — Information security management system (ISMS) certification
- SOC 2 Type II — Independent assurance over security, availability, and confidentiality controls

Governance should include a cross-functional AI Safety and Security Review Board responsible for approving model changes, reviewing incident reports, and overseeing periodic third-party audits and penetration tests.

8. Conclusion and Recommendations

Securing an AI-powered healthcare diagnosis platform requires more than traditional application security — it demands a layered architecture that treats the AI model itself as a protected asset, alongside the PHI it processes. By combining Zero Trust network design, strong identity and access controls, end-to-end encryption, AI-specific defenses against adversarial and poisoning attacks, and a human-in-the-loop clinical safety net, the proposed architecture substantially reduces both cybersecurity risk and patient-safety risk.

Key recommendations for implementation teams:

- Adopt security-by-design from the earliest architecture stage, not as a retrofit
- Treat the AI model and training pipeline as first-class assets requiring dedicated protection
- Maintain continuous monitoring for both cybersecurity events and model performance drift
- Keep a qualified clinician in the decision loop for every AI-assisted diagnosis
- Schedule regular third-party audits, penetration tests, and compliance reviews

Following this framework enables healthcare organizations to responsibly harness AI's diagnostic potential while safeguarding patient trust, data privacy, and regulatory compliance.